System Requirement for Frontend and Backend

Meshaai — System Contracts & Integration Requirements

Unified Technical Contract & User Responsibilities for Backend & Frontend Integration
Document Version: `1.0.0`
Target Stack: Spring Boot 4 / Java 21 Modulith ↔ Web & Mobile Frontends

---

Table of Contents

1. Global Protocols & Communication Standards
2. Customer Journey & Integration Contracts
   - 2.1 Anonymous Catalog Discovery & Currency Localization
   - 2.2 Delivery Zone & Serviceability Check
   - 2.3 Passwordless Authentication & Identity (Phone OTP)
   - 2.4 Session Rotation & Token Refresh
   - 2.5 Customer Profile & Address Book Management
3. Admin & Operations Journey & Integration Contracts
   - 3.1 Admin Authentication & Session Lifecycle
   - 3.2 Customer & Risk Management
   - 3.3 Catalog & Menu Availability Management
   - 3.4 Kitchens & Delivery Zones Management
   - 3.5 Delivery Fee Rules & Promotions Engine
   - 3.6 Platform Kill-Switches & Global Settings
4. Kitchen Operator Responsibilities & Dispatch Flow
5. Frontend Implementation Guidelines & UI Recommendations

---

1. Global Protocols & Communication Standards

1.1 Base URLs & Environments

- **Local Development:** `http://localhost:8080`
- **Swagger / OpenAPI Documentation:** `GET /docs` (Swagger UI), `GET /api-docs/public`, `GET /api-docs/admin`

1.2 Global Request Headers

Header Name	Type	Requirement	Description
`Content-Type`	String	**Required** on POST/PUT	Must always be `application/json`.
`Authorization`	String	**Required** on Protected Routes	Bearer token format: `Bearer <JWT_ACCESS_TOKEN>`.
`X-Correlation-Id`	String (UUID)	Optional (Recommended)	Frontend-generated UUID for end-to-end request tracing. Echoed in all responses.
`CF-IPCountry` / `X-Country-Code`	String (ISO-2)	Optional	Geo-IP header (e.g. `NG`, `US`, `GB`, `GH`) used for automatic visitor currency detection.

1.3 Monetary Representation Contract

- **Backend Storage & API Minor Units:** All monetary values sent in request bodies or calculated internally are positive integers in **minor units** (e.g. Nigerian Kobo: `50000` = ₦500.00, USD Cents: `250` = $2.50).
- **Localized Display Object (`PriceDto`):** Endpoints that return customer-facing prices output a structured price object:

```
{
  "currency": "NGN",
  "amount": 50000,
  "formatted": "₦500.00"
}
```

1.4 Global RFC 7807 Error Envelope

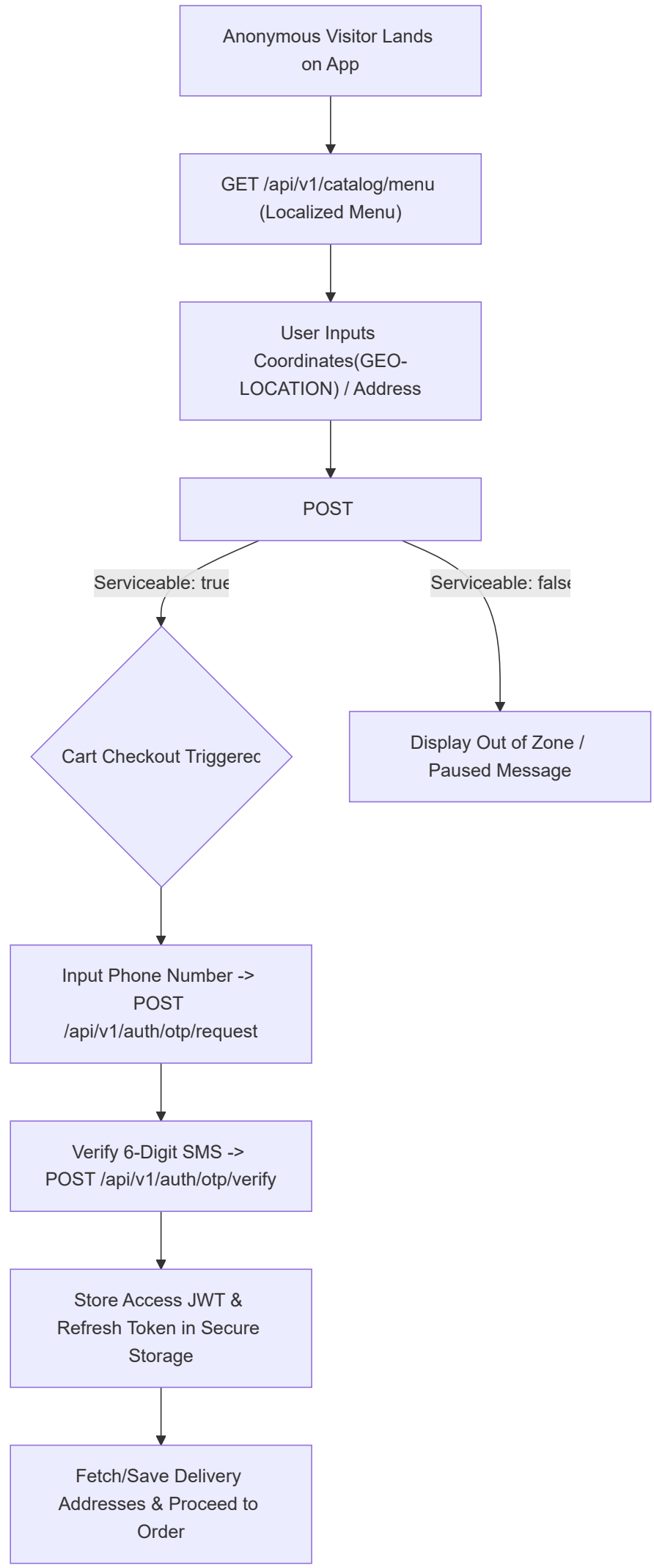
Whenever an error occurs (HTTP 4xx or 5xx), the backend returns a standardized problem detail payload. e.g.:

```
{
  "type": "https://meshaai.com/errors/invalid-otp",
  "title": "Bad Request",
  "status": 400,
  "detail": "Invalid verification code. 3 attempt(s) remaining.",
  "instance": "/api/v1/auth/otp/verify",
  "code": "INVALID_OTP",
  "correlationId": "4c8f25b2-32a1-432d-96cf-712808c4a169"
}
```

> **Important**
>
> **Frontend Error Handling Rule:** The frontend must branch its UI/toast logic on the `code` property (which is stable and guaranteed), **never** by regex-matching the human-readable `detail` string.. What this means is that you will output a clear message base on the code and not the detail(the details is for logging and trail purposes).

---

2. Customer Journey & Integration Contracts



2.1 Anonymous Catalog Discovery & Currency Localization

Requirement

Customers must be able to explore the menu, browse categories, view dishes, modifiers, and see accurate prices without creating an account or logging in.

API Contract

- **Endpoint:** `GET /api/v1/catalog/menu` (or `GET /catalog/menu`)
- **Query Parameters (Optional):** `?currency=USD` (explicit visitor currency override)
- **Headers (Optional):** `CF-IPCountry: US` (Cloudflare geo-IP header)
- **Expected Success Response (`200 OK`):**

```
{
  "currency": "NGN",
  "categories": [
    {
      "id": "bread-2-eggs",
      "name": "Bread and Egg",
      "items": [
        {
```

```
          "id": "---",
          "name": "Bread with 2 fried Eggs",
          "description": "Local meshai toast.",
          "available": true,
          "basePrice": {
            "currency": "NGN",
            "amount": 350000,
            "formatted": "₦3,500.00"
          },
          "modifierGroups": [
            {
              "id": "hot-dogs",
              "name": "Choose Adds-on",
              "minSelections": 1,
              "maxSelections": 2,
              "options": [
                {
                  "id": "sausage",
                  "name": "Sausage",
                  "price": { "currency": "NGN", "amount": 120000, "formatted": "₦1,200.00" }
                }
              ]
            }
          ]
        }
      ]
    }
  ]
}
```


Constraints & Edge Cases

Condition	HTTP Status	Error `code`	Frontend Handling
Unsupported `?currency=XYZ` override	`200 OK` (Fallback)	N/A	Backend gracefully falls back to base currency (`NGN`) or Geo-IP detected currency.
Item is sold out (`available: false`)	`200 OK`	N/A	Frontend must disable "Add to Cart" button and display a "Sold Out" overlay badge. But this will seldom be this case

Frontend UI Suggestions

- **Currency Switcher:** A dropdown selector in the navigation bar listing supported currencies (`NGN` , `USD` , `GBP` , `EUR` , `CAD` , `GHS` , `KES`). Selecting an item sets the `?currency=` query parameter globally.
- **Modifier Modals:** Radio buttons for single-choice modifier groups (`min=1, max=1`), and checkboxes with selection counters for multi-choice modifier groups (`maxSelections > 1`).

2.2 Delivery Zone & Serviceability Check

Requirement

Before placing an order, the customer checks if their delivery location is covered by a Meshaai kitchen, calculates the delivery fee, and checks whether the kitchen is open for immediate preparation or scheduled pre-orders.

API Contract

- **Endpoint:** `POST /api/v1/delivery/check`
- **Get this from customer location**
- **Request Body:**


```
{
  "latitude": 9.0778,
  "longitude": 7.4819
}
```


- **Expected Success Response (`200 OK` — Inside Active Zone):**


```
{
  "serviceable": true,
  "kitchenId": 1,
  "kitchenName": "Meshaai Kitchen - Abuja Wuse 2",
  "distanceKm": 3.42,
  "deliveryFee": {
    "currency": "NGN",
    "amount": 80000,
    "formatted": "₦800.00"
  },
  "mode": "NOW",
  "ruleApplied": {
    "ruleId": 2,
    "ruleName": "Tier 2: 3-5km Standard",
    "type": "DISTANCE_BAND"
  }
}
```


- **Expected Success Response (`200 OK` — Outside Operating Hours / Pre-Order):**

```
{
  "serviceable": true,
  "kitchenId": 1,
  "kitchenName": "Meshaai Kitchen - Abuja Wuse 2",
  "distanceKm": 1.20,
  "deliveryFee": { "currency": "NGN", "amount": 50000, "formatted": "₦500.00" },
  "mode": "PRE_ORDER",
  "scheduledFor": {
    "utc": "2026-10-04T05:00:00Z",
    "local": "2026-10-04T06:00:00+01:00",
    "timezone": "Africa/Lagos"
  }
}
```


- **Expected Response (`200 OK` — Unserviceable Location):**


```
{
  "serviceable": false,
  "reason": "OUT_OF_ZONE"
}
```


Constraints & Edge Cases

Condition / Reason	Response Payload	Frontend Handling
`reason: "OUT_OF_ZONE"`	`serviceable: false`	Display banner: *"Sorry, we do not deliver to this location yet."*
`reason: "KITCHEN_PAUSED"`	`serviceable: false`	Display banner: *"The nearest kitchen is temporarily paused due to high order volume. Please check back shortly."*
`reason: "ORDERING_PAUSED"`	`serviceable: false`	Display modal: *"Online ordering is currently suspended across all kitchens for scheduled platform maintenance."*
Missing / null coordinates	`400 BAD_REQUEST`	Form validation: prompt user to allow browser geolocation or pick an address from the map.

Frontend UI Suggestions

- **Address & Pin Picker:** Map interface or Google Places autocomplete where picking an address extracts `latitude` and `longitude` and immediately pings `/delivery/check`.
- **Fulfillment Pill Badge:** If `mode === "NOW"`, show green badge *"Delivering in few mins"*. If `mode === "PRE_ORDER"`, show yellow badge *"Kitchen opens at 06:00 AM (Pre-order now)"*.

2.3 Passwordless Authentication & Identity (Phone OTP)

Requirement

Customers authenticate without passwords. They enter their phone number (Nigerian or international) and verify a 6-digit SMS OTP to automatically create an account or log into their existing profile.

Step 1: Request OTP

- **Endpoint:** `POST /api/v1/auth/otp/request`
- **Request Body:**


```
{
  "phone": "+2348039276495"
}
```


- **Expected Success Response (`200 OK`):**


```
{
  "message": "Verification code dispatched successfully",
  "expiresInSeconds": 300
}
```


Step 2: Verify OTP

- **Endpoint:** `POST /api/v1/auth/otp/verify`
- **Request Body:**


```
{
  "phone": "+2348039276495",
  "code": "760395"
}
```


- **Expected Success Response (`200 OK`):**


```
{
  "accessToken": "eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9...",
  "refreshToken": "9f8e7d6c-5b4a-3210-fedc-ba9876543210",
  "tokenType": "Bearer",
  "expiresIn": 900,
  "customer": {
    "id": 104,
    "phone": "+2348039276495",
    "fullName": null,
    "email": null,
    "isNewCustomer": true
  }
}
```

Constraints & Error Matrix

Scenario	Status	Error `code`	Frontend Behavior
Invalid phone format (e.g. missing country code or invalid digits)	`400`	`INVALID_PHONE_NUMBER`	Show inline input validation error under phone field.
Incorrect OTP code (Attempts 1 to 4)	`400`	`INVALID_OTP`	Highlight OTP input in red; display remaining attempts (e.g. *"Incorrect code. 3 attempts remaining."*).
5 Consecutive Failed Attempts	`429`	`OTP_LOCKED`	Lock the OTP input for 15 minutes;
OTP Expired (> 5 minutes)	`400`	`OTP_EXPIRED`	Clear OTP boxes; show *"Code has expired. Request a new OTP."*
Request rate limit exceeded (> 3 requests/min per phone)	`429`	`RATE_LIMIT_EXCEEDED`	Disable "Resend Code" button;
Customer is blocked by Admin	`403`	`CUSTOMER_BLOCKED`	Show error dialog: *"Your account has been suspended. Please contact support."*
SMS Gateway (Termii) downtime or network timeout	`500`	`SMS_DELIVERY_FAILED`	Show alert: *"Unable to send SMS at this moment. Please try again later."*

Frontend UI Suggestions

- **Phone Input:** Use a phone number input component with a country selector dropdown (defaulting to Nigeria `+234`).
- **Resend OTP Timer:** A 60-second countdown timer on the "Resend OTP" button to prevent client-side spamming.
- **Auto-Submit OTP:** Auto-submit the form as soon as the 6th digit is typed or pasted.

2.4 Session Rotation & Token Refresh

Requirement

The customer's `accessToken` expires every 15 minutes. The frontend must silently use the 90-day `refreshToken` to acquire a new access token without interrupting the user's checkout or browsing experience.

API Contract

- **Endpoint:** `POST /api/v1/auth/session/refresh`
- **Request Body:**

```
{
  "refreshToken": "9f8e7d6c-5b4a-3210-fedc-ba9876543210"
}
```

- **Expected Success Response (`200 OK`):**

```
{
  "accessToken": "eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9...",
  "refreshToken": "1a2b3c4d-5e6f-7890-abcd-ef1234567890",
  "tokenType": "Bearer",
  "expiresIn": 900
}
```

Constraints & Security Protocols

Scenario	Status	Error `code`	Frontend Security Action
Expired Refresh Token (> 90 days)	`401`	`SESSION_EXPIRED`	Clear local storage / secure store and redirect to login modal.
Revoked Session (Logged out or killed by Admin)	`401`	`SESSION_REVOKED`	Purge tokens and force re-authentication.
Token Replay Attack (Re-sending an old, already rotated refresh token)	`401`	`SESSION_REVOKED`	**Backend auto-revokes the entire device session.** Frontend must wipe tokens immediately.

Frontend UI / Interceptor Implementation

- Set up an HTTP client interceptor.
- Upon receiving a `401 UNAUTHORIZED` on any protected route, queue failed requests, call `/api/v1/auth/session/refresh`, update the in-memory token, and replay the queued requests seamlessly.

2.5 Customer Profile & Address Book Management

Requirement

Authenticated customers can manage their profile details (Name, Email, Preferred Currency) and save delivery addresses (Home, Office, etc.) with coordinates.

Endpoints

- `GET /api/v1/customer/profile` — View current customer profile.
- `PUT /api/v1/customer/profile` — Update Name, Email, Preferred Currency.
- `GET /api/v1/customer/addresses` — List saved delivery addresses.
- `POST /api/v1/customer/addresses` — Create new delivery address.
- `PUT /api/v1/customer/addresses/{id}` — Update existing address.
- `DELETE /api/v1/customer/addresses/{id}` — Delete address.
- `PUT /api/v1/customer/addresses/{id}/default` — Set address as default.

Save Address Request Body:

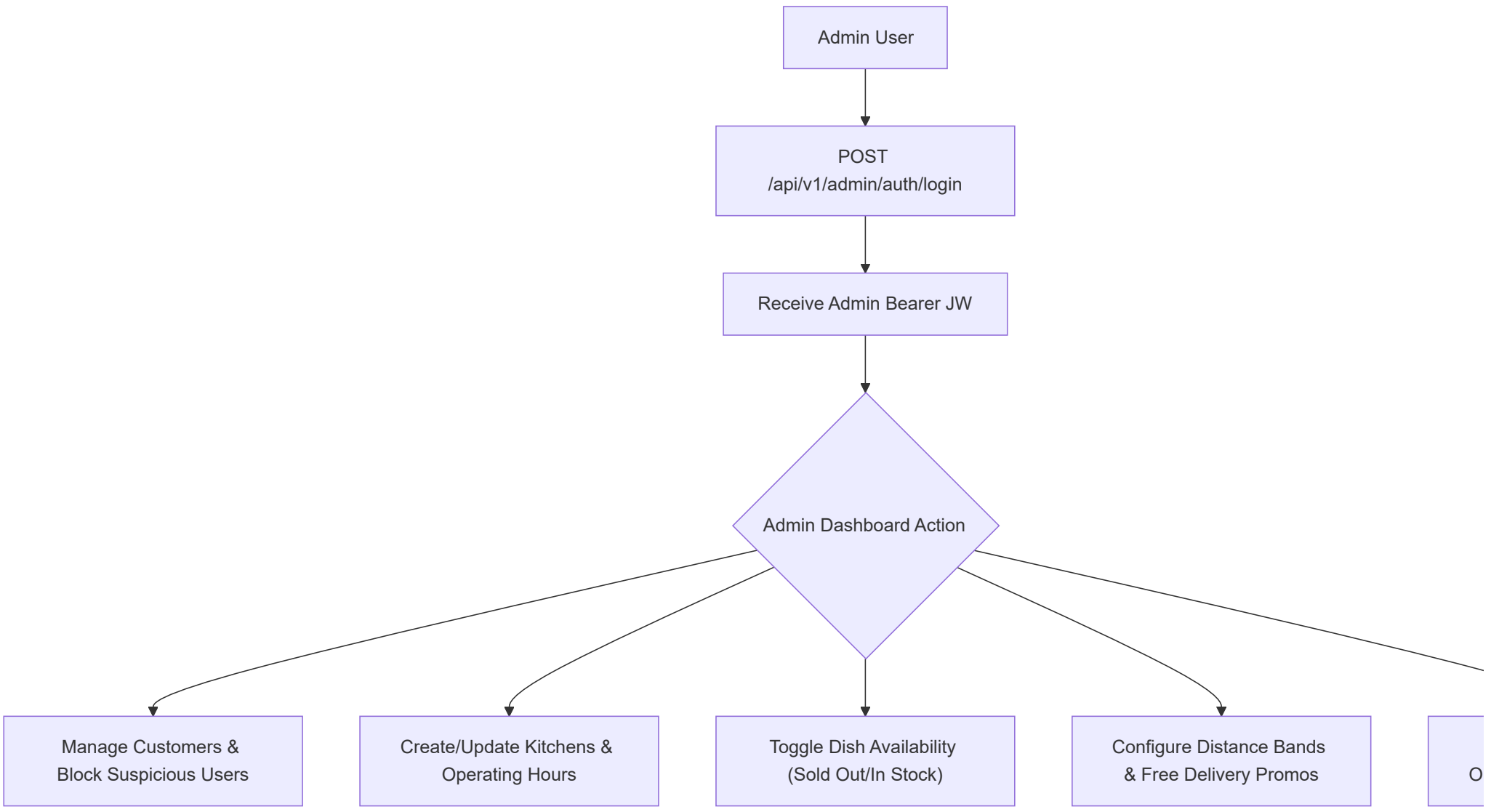
```
{
  "label": "Home",
  "streetAddress": "Plot 124 Aminu Kano Crescent",
  "building": "Apartment 4B",
  "landmark": "Opposite KFC Wuse 2",
  "latitude": 9.0778,
  "longitude": 7.4819,
  "isDefault": true
}
```

Frontend UI Suggestions

- **Address Cards:** Saved addresses displayed as selectable cards with a radio button indicating the active delivery destination.
- **"Set as Default" Toggle:** Toggle switch in the address creation modal.

---

3. Admin & Operations Journey & Integration Contracts



3.1 Admin Authentication & Session Lifecycle

Requirement

Admins authenticate using email and password. Protected admin routes require `ROLE_ADMIN` in the JWT token.

API Contract

- **Endpoint:** `POST /api/v1/admin/auth/login`
- **Request Body:**

```
{
  "email": "admin@meshaai.com",
  "password": "SecureAdminPassword123!"
}
```

- **Expected Success Response (`200 OK`):**

```
{
  "accessToken": "eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9...",
  "refreshToken": "admin-refresh-uuid-string",
  "tokenType": "Bearer",
  "expiresIn": 900,
  "admin": {
    "id": 1,
    "email": "admin@meshaai.com",
    "fullName": "Meshaai System Administrator"
  }
}
```

Constraints & Edge Cases

Scenario	Status	Error `code`	Frontend Handling
Wrong email or password	`401`	`INVALID_CREDENTIALS`	Show error message: *"Invalid email or password."*
Non-admin attempting to hit `/api/v1/admin/**`	`403`	`FORBIDDEN`	Redirect to Admin Login page.

3.2 Customer & Risk Management

Requirement

Admins can view registered customers, search by phone or name, review order histories, block fraudulent users, and terminate active sessions.

Endpoints

- `GET /api/v1/admin/customers?page=0&size=20&search=0803` — Paginated customer list.
- `GET /api/v1/admin/customers/{id}` — Customer details, addresses, and device sessions.
- `PUT /api/v1/admin/customers/{id}/block` — Block customer (immediately denies all OTP requests and revokes sessions).
- `PUT /api/v1/admin/customers/{id}/unblock` — Unblock customer.
- `POST /api/v1/admin/customers/{id}/sessions/revoke-all` — Force logout across all customer devices.

Frontend UI Suggestions

- **Customer Status Badge:** Green chip for *"Active"*, Red chip for *"Blocked"*.
- **Block Confirmation Modal:** Destructive action dialog requiring explicit confirmation before blocking a customer.

3.3 Catalog & Menu Availability Management

Requirement

Admins can manage menu items and instantly mark items as available or 86'd (sold out) when ingredients run out during a service rush.

API Contract: Toggle Item Availability

- **Endpoint:** `PATCH /api/v1/admin/catalog/items/{id}/availability`
- **Headers:** `Authorization: Bearer <ADMIN_JWT>`
- **Request Body:**

```
{
  "available": false
}
```

- **Expected Success Response (`200 OK`):**

```
{
  "id": "signature-smokey-jollof",
  "name": "Signature Smokey Jollof",
  "available": false
}
```

Frontend UI Suggestions

- **Quick-Toggle Table Switch:** An on/off switch in the admin inventory table that immediately dispatches the `PATCH` request with optimistic UI updates.

3.4 Kitchens & Delivery Zones Management

Requirement

Admins configure kitchens, geographic coordinates, operating hours, delivery radius, operator contacts, and pause/resume operational status.

Endpoints

- `GET /api/v1/admin/kitchens` — List all kitchens.
- `POST /api/v1/admin/kitchens` — Create new kitchen.
- `PUT /api/v1/admin/kitchens/{id}` — Update kitchen details and operating hours.
- `PATCH /api/v1/admin/kitchens/{id}/pause` — Toggle kitchen paused/active status.
- `DELETE /api/v1/admin/kitchens/{id}` — Delete kitchen.

Create Kitchen Request Body:

```
{
  "name": "Meshaai Kitchen - Abuja Wuse 2",
  "latitude": 9.0778,
  "longitude": 7.4819,
  "timezone": "Africa/Lagos",
  "openTime": "06:00:00",
  "closeTime": "19:00:00",
  "radiusKm": 7.0,
  "operatorName": "Ibrahim Wuse Ops",
  "operatorPhone": "+2348039276495",
  "active": true
}
```

Constraints & Validation Rules

Field / Rule	Constraint	Error `code`
`closeTime <= openTime`	Closing time must be strictly after opening time. Inverted hours are rejected.	`400 INVALID_HOURS`
`radiusKm`	Must be a positive decimal > 0.0 (e.g. `7.0`).	`400 BAD_REQUEST`
`operatorPhone`	Must be a valid E.164 phone number.	`400 INVALID_PHONE_NUMBER`
`timezone`	Must be a valid IANA timezone identifier (e.g. `"Africa/Lagos"`).	`400 BAD_REQUEST`

Frontend UI Suggestions

- **Time Pickers:** 24-hour time pickers enforcing `closeTime > openTime`.
- **Coverage Map Circle:** Interactive map displaying a 7.0 km radius circle around the kitchen's latitude and longitude coordinates.

3.5 Delivery Fee Rules & Promotions Engine

Requirement

Admins define distance-tiered fee bands (scoped to specific kitchens) and promotional free delivery windows overriding standard rates by priority.

API Contract: Create Fee Rule

- **Endpoint:** `POST /api/v1/admin/delivery-fee-rules`
- **Request Body (Distance Band):**

```
{
  "name": "Abuja Wuse 0-3km Tier",
  "type": "DISTANCE_BAND",
  "priority": 10,
  "minDistanceKm": 0.0,
  "maxDistanceKm": 3.0,
  "feeAmount": 50000,
  "currency": "NGN",
  "kitchenId": 1
}
```

- **Request Body (Promotional Free Delivery Window):**

```
{
  "name": "Sunday Lunch Free Delivery Promo",
  "type": "FREE_WINDOW",
  "priority": 100,
  "windowStart": "2026-10-04T12:00:00Z",
  "windowEnd": "2026-10-04T15:00:00Z",
  "feeAmount": 0,
  "currency": "NGN",
  "kitchenId": 1
}
```

Constraints & Validation Rules

Rule	Constraint	Error `code`
`currency`	Must be a valid 3-letter uppercase ISO-4217 code (e.g. `NGN`, `USD`).	`400 INVALID_CURRENCY`
`DISTANCE_BAND`	Must provide `minDistanceKm`, `maxDistanceKm`, and `kitchenId`.	`400 BAD_REQUEST`
`FREE_WINDOW`	Must provide `windowStart` and `windowEnd` where `end > start`.	`400 BAD_REQUEST`

Frontend UI Suggestions

- **Rule Type Selector:** A dropdown or segmented button switching between *"Distance Band (Per Kitchen)"* and *"Promotional Time Window"*.
- **Priority Indicator:** Higher priority rules (e.g. `100`) evaluate before lower priority rules (`10`).

3.6 Platform Kill-Switches & Global Settings

Requirement

Admins have access to emergency platform controls, such as a master kill-switch to pause ordering platform-wide during extreme weather, holidays, or system maintenance.

API Contract: Toggle Global Ordering Pause

- **Endpoint:** `PUT /api/v1/admin/settings/ordering_paused`
- **Request Body:**

```
{
  "value": "true"
}
```

- **Expected Success Response (`200 OK`):**

```
{
  "key": "ordering_paused",
  "value": "true",
  "description": "Global ordering pause kill switch",
```

```
  "updatedAt": "2026-10-03T13:00:00Z",
  "updatedBy": "admin@meshaai.com"
}
```

Frontend UI Suggestions

- **Master Emergency Banner:** High-visibility toggle switch in the admin header with a warning dialogue before pausing global operations.

---

4. Kitchen Operator Responsibilities & Dispatch Flow

Kitchen operators do not log in to complex desktop software; their operations are streamlined via real-time SMS notifications and quick mobile dashboard actions:

1. **Order Alert SMS:** The kitchen operator receives an instant SMS notification on their designated `operatorPhone` whenever a new order is confirmed in their kitchen zone.
2. **Emergency Pause:** If a kitchen experiences equipment failure or an overwhelming queue, the operator contacts the admin or toggles their kitchen status via `PATCH /api/v1/admin/kitchens/{id}/pause` to prevent further incoming orders.
3. **Multi-Kitchen Redirection:** If Kitchen A is paused, the routing engine automatically directs nearby customers to covering Kitchen B (if within Kitchen B's radius) without dropping the sale.

---

5. Frontend Implementation Guidelines & UI Recommendations

5.1 Authentication State Management

```
interface AuthState {
  isAuthenticated: boolean;
  accessToken: string | null;
  refreshToken: string | null;
  customer: CustomerProfile | null;
}
```

- Store `refreshToken` in secure storage (`HttpOnly` cookies on web, or `EncryptedSharedPreferences` / iOS `Keychain` on mobile).
- Keep `accessToken` in memory.

5.2 Form Field Validation & Input Masking

Form Field	Recommended Frontend Mask / Component
Phone Number	Phone input with international flag selector; auto-formats to E.164 (e.g. `+234 803 927 6495`).
OTP Input	6 individual numeric input boxes with auto-focus advance and paste support.
Time Pickers	24-hour time selector format `HH:mm:ss` .
Fee Amounts	Numeric input with currency prefix formatting; converts decimal input (e.g. `₦500.00`) to minor units (`50000`) before sending to backend.

5.3 Complete Error Code ↔ Toast Mapping Reference

Backend Error `code`	HTTP Status	Recommended User-Facing Toast / Alert Message
`INVALID_PHONE_NUMBER`	400	"Please enter a valid phone number including country code."
`INVALID_OTP`	400	"Incorrect verification code. Please check and try again."
`OTP_EXPIRED`	400	"Verification code has expired. Please request a new code."
`OTP_LOCKED`	429	"Too many failed attempts. Your account is temporarily locked for 15 minutes."
`RATE_LIMIT_EXCEEDED`	429	"Too many requests. Please wait a moment before trying again."
`CUSTOMER_BLOCKED`	403	"Your account has been restricted. Please contact Meshaai customer support."
`OUT_OF_ZONE`	200	"Delivery is not yet available at this location."
`KITCHEN_PAUSED`	200	"The kitchen serving your area is temporarily paused. Please check back shortly."
`ORDERING_PAUSED`	200	"Ordering is temporarily closed for maintenance. Please check back soon."
`INVALID_HOURS`	400	"Kitchen closing time must be later than the opening time."
`INVALID_CURRENCY`	400	"Invalid currency code. Please select a valid 3-letter currency code (e.g. NGN, USD)."
`SESSION_EXPIRED` / `SESSION_REVOKED`	401	"Your session has expired. Please log in again."